Аудит переносимости — 2026-10-29

Состояние до работы

Область	Наблюдение
Код	один файл server.py (~727 строк): конфигурация, хранение, аутентификация, квиз, почта, keep-alive
Зависимости	закреплены точными версиями (==) — хорошо
Тесты	отсутствовали
CI	отсутствовал
Безопасность	пароль Gmail в коде, админ-код ADMIN123, CORS * + credentials, keep-alive при импорте
Документация	подробный README на русском, без архитектурных документов

Что сделано

#	Изменение	Почему
1	Убраны секреты из кода (SMTP), админ-код из окружения, CORS из окружения, keep-alive по флагу	устранение реальных уязвимостей, а не косметика
2	15 тестов: аутентификация, квиз, защитные свойства	без тестов любое изменение небезопасно
3	Makefile, scripts/doctor.sh, scripts/smoke-test.sh, scripts/docs-check.sh	единые точки входа вместо инструкций «для Windows»
4	.env.example, .gitignore (включая data.db), requirements-dev.txt	конфигурация без секретов, воспроизводимая установка
5	.github/workflows/ci.yml (тесты, lint, запуск без опциональной конфигурации, документация)	раньше проверок не было вообще
6	BUILD.md, docs/index.md, docs/architecture/system-context.md	сборка и устройство описаны с нуля
7	docs/database.md, docs/api/conventions.md, docs/operations/*, docs/modules/*	данные, контракты, эксплуатация, спецификации модулей
8	docs/verification/matrix.md, этот аудит	отличать доказанное от обещанного
9	README: раздел с командами	документация начинается с рабочей команды

Чего сознательно не делал

- **Не разбивал server.py на модули.** Разделение на слои зафиксировано документом, но массовая перестановка кода без второго потребителя создаёт риск и не даёт измеримой

пользы. Когда появится повод (рост файла, второй клиент), первым выносится хранение и аутентификация — у них уже есть тесты.

- **Не чистил историю git.** Секреты в истории остаются; правильная реакция — ротация ключей (описана).

Открытые вопросы для владельца

1. Отозвать пароль приложения Gmail и задать `ADMIN_CODE`.
2. Подключить постоянный диск на Render — иначе `data.db` теряется при перезапуске.
3. Добавить rate limit на вход и восстановление пароля (сейчас нет).
4. Решить, нужна ли выгрузка заявок в файл.

Дополнение: что нашёл первый прогон CI

Симптом	Настоящая причина	Исправлено
Smoke-тест в CI: все проверки вернули `000`, сервер «не поднялся»	`server.py` запускал uvicorn на жёстко заданном порту 5000, а проверки, Makefile и `doctor.sh` ждали 8000	порт и хост читаются из `PORT`/`HOST`, по умолчанию 8000 — единый адрес во всех документах и скриптах
В CI стартовал перезагрузчик uvicorn	`reload=True` был зашит в код	`RELOAD=1` включает автоперезагрузку только для разработки
Линт падал у всех по-разному	не было `ruff.toml`, результат зависел от конфигурации машины	конфигурация в репозитории, версия ruff закреплена (`ruff==0.8.4`), правило задокументировано в `docs/development/code-style.md`

Порт — не косметика: платформы вроде Render сами назначают `PORT` и считают сервис нездоровым, если он слушает другой порт. Теперь `python server.py`, `make run`, CI и `render.yaml` согласованы.